

DER.7 Bug-Bounty-Programme

1 Beschreibung

1.1 Einleitung

Die Komplexität moderner IT-Landschaften führt dazu, dass trotz umfassender interner Sicherheitsprüfungen Schwachstellen in produktiven Systemen verbleiben können. Bug-Bounty- und Vulnerability-Disclosure-Programme (VDP) bieten einen strukturierten und kooperativen Rahmen, um das globale Fachwissen externer, ethischer Sicherheitsforschender zur Identifizierung dieser Schwachstellen zu nutzen. Anstatt auf eine zufällige oder potenziell schädliche Entdeckung zu warten, schaffen Institutionen proaktiv einen Anreiz und einen sicheren Kanal für die Meldung von Sicherheitslücken.

Dieser Baustein ergänzt die reaktiven und proaktiven Sicherheitsmaßnahmen einer Institution. Während Bausteine wie DER.1 Detektion von sicherheitsrelevanten Ereignissen und DER.2.1 Behandlung von Sicherheitsvorfällen auf die Erkennung und Behandlung von Angriffen abzielen, öffnet dieser Baustein den Blick nach außen und nutzt die kollektive Expertise zur Schwachstellenidentifikation.

1.2 Zielsetzung

Ziel dieses Bausteins ist es, einen systematischen Weg aufzuzeigen, wie Institutionen Programme zur Meldung von Schwachstellen durch Externe planen, rechtssicher aufsetzen, durchführen und nachbereiten können. Dadurch sollen unentdeckte Sicherheitslücken minimiert, die Reaktionszeiten auf neu gefundene Schwachstellen verkürzt und kooperative Beziehungen zur Sicherheitsforschungsgemeinschaft aufgebaut werden.

1.3 Abgrenzung und Modellierung

Der Baustein DER.7 Bug-Bounty-Programme ist auf den Informationsverbund einmal anzuwenden.

Dieser Baustein beschreibt nicht die technische Behebung der gemeldeten Schwachstellen. Die Anforderungen an einen funktionierenden Schwachstellen- und Patchmanagement-Prozess sind im Baustein OPS.1.1.3 Patch- und Änderungsmanagement beschrieben. Die Reaktion auf kritische, bereits ausgenutzte Schwachstellen ist in DER.2.1 Behandlung von Sicherheitsvorfällen geregelt.

2 Gefährdungslage

Für den Baustein DER.7 Bug-Bounty-Programme sind folgende spezifische Bedrohungen und Schwachstellen von besonderer Bedeutung:

Unentdeckte Schwachstellen in produktiven Anwendungen

Trotz etablierter Entwicklungs- und Testprozesse können Schwachstellen in Software und Systemen unentdeckt in den Produktionsbetrieb gelangen. Diese stellen ein erhebliches Risiko dar, da sie von Angreifern ausgenutzt werden können, lange bevor sie durch interne Mechanismen bemerkt werden.

Unkoordinierte Offenlegung von Schwachstellen

Wenn Sicherheitsforschende Schwachstellen entdecken, aber keinen klaren und sicheren Meldekanal vorfinden, können sie diese unkoordiniert veröffentlichen ("Full Disclosure"). Dies gibt der Institution keine Zeit, die Lücke zu schließen, und setzt die Systeme und Daten einem hohen Angriffsrisiko aus.

Rechtsunsicherheit im Umgang mit externen Meldenden

Fehlt eine klare rechtliche Zusicherung ("Safe Harbor"), könnten Sicherheitsforschende aus Angst vor rechtlichen Konsequenzen davon absehen, gefundene Schwachstellen zu melden. Ebenso kann auf Seiten der Institution Unsicherheit darüber bestehen, wie mit Meldungen und den Forschenden umzugehen ist, was zu fehlerhaften oder eskalierenden Reaktionen führen kann.

Ineffiziente Bearbeitung von Schwachstellenmeldungen

Ohne einen definierten Prozess laufen Meldungen über unspezifische Kanäle (z. B. allgemeine E-Mail-Adressen, soziale Medien) ein. Dies führt dazu, dass Meldungen verloren gehen, nicht rechtzeitig an die zuständigen Stellen weitergeleitet oder von unqualifiziertem Personal nicht als sicherheitsrelevant erkannt werden.

Reputationsschaden durch unsachgemäße Kommunikation

Eine langsame, unprofessionelle oder abweisende Kommunikation mit Sicherheitsforschenden, die eine Schwachstelle melden, kann zu erheblichem Reputationsschaden in der Fachgemeinschaft führen. Dies kann zukünftige Meldungen verhindern und die Institution öffentlich als unkooperativ darstellen.

3 Anforderungen

Im Folgenden sind die spezifischen Anforderungen des Bausteins DER.7 Bug-Bounty-Programme aufgeführt. Grundsätzlich ist der Informationssicherheitsbeauftragte (ISB) für die Erfüllung der Anforderungen zuständig. Abweichungen werden in den entsprechenden Anforderungen gesondert genannt.

Zuständigkeiten	Rollen
-----------------	--------

Grundsätzlich zuständig	Informationssicherheitsbeauftragter (ISB)
Weitere Zuständigkeiten	Institutionsleitung, Fachverantwortliche, IT-Betrieb, Entwickler

3.1 Basis-Anforderungen

Die folgenden Anforderungen MÜSSEN vorrangig erfüllt werden.

DER.7.A1 Festlegung einer Richtlinie für Schwachstellenmeldungen (B) [Institutionsleitung]

Es MUSS eine von der Institutionsleitung verabschiedete Richtlinie für den Umgang mit extern gemeldeten Schwachstellen existieren. Diese Richtlinie MUSS die grundlegenden Ziele, Verantwortlichkeiten und die Verpflichtung der Institution zur Zusammenarbeit mit Sicherheitsforschern verbindlich festlegen.

DER.7.A2 Erstellung und Veröffentlichung einer Vulnerability Disclosure Policy (B)

Es MUSS eine klare und leicht auffindbare Vulnerability Disclosure Policy (VDP) erstellt und veröffentlicht werden. Die VDP MUSS eine Erklärung der Absicht, den präferierten Meldekanal, eine Beschreibung der im Geltungsbereich liegenden Systeme (Scope) sowie die Arten der ausdrücklich nicht gestatteten Tests enthalten.

DER.7.A3 Einrichtung eines dedizierten und sicheren Meldekanals (B) [IT-Betrieb]

Es MUSS ein klar definierter und sicherer Kanal für die Entgegennahme von Schwachstellenmeldungen eingerichtet werden (z. B. über eine definierte E-Mail-Adresse mit veröffentlichtem kryptografischem Schlüssel). Dieser Kanal MUSS regelmäßig überwacht werden.

DER.7.A4 Formulierung einer rechtlichen Schutzzusage (Safe Harbor) (B) [Institutionsleitung]

Die VDP MUSS eine rechtliche Schutzzusage (Safe Harbor) enthalten. Es MUSS zugesichert werden, dass die Institution keine rechtlichen Schritte gegen Personen einleitet, die Schwachstellen im Rahmen der in der VDP definierten Regeln und in gutem Glauben suchen und melden.

DER.7.A5 Definition eines initialen Triage-Prozesses (B)

Es MUSS ein interner Prozess definiert werden, wie eingehende Meldungen bestätigt, auf ihre

Validität geprüft und an die zuständigen Stellen weitergeleitet werden. Alle Meldenden MÜSSEN zeitnah eine Eingangsbestätigung erhalten.

3.2 Standard-Anforderungen

Gemeinsam mit den Basis-Anforderungen entsprechen die folgenden Anforderungen dem Stand der Technik bei normalem Schutzbedarf. Sie SOLLTEN grundsätzlich erfüllt werden.

DER.7.A6 Detaillierte Definition von Scope und Testregeln (S) **[Fachverantwortliche]**

Der Geltungsbereich (Scope) des Programms SOLLTE detailliert definieren, welche Anwendungen, Systeme und Arten von Schwachstellen abgedeckt sind und welche explizit ausgeschlossen werden. Es SOLLTEN klare Regeln für die Durchführung von Tests festgelegt werden, um Störungen des produktiven Betriebs zu vermeiden (z. B. Verbot von DoS-Tests und Social Engineering).

DER.7.A7 Etablierung eines transparenten Belohnungssystems (S) **[Institutionsleitung]**

Für ein Bug-Bounty-Programm SOLLTE ein transparentes und motivierendes Belohnungssystem (Bounty-Schema) etabliert werden. Die Höhe monetärer Belohnungen SOLLTE sich an der Kritikalität der Schwachstelle (z. B. anhand von CVSS-Scores) orientieren. Ergänzend SOLLTEN nicht-monetäre Anreize (z. B. eine Hall of Fame) angeboten werden.

DER.7.A8 Etablierung eines Kommunikations- und Eskalationskonzepts (S)

Es SOLLTE ein Kommunikationskonzept erstellt werden, das klare Service-Level-Ziele für die Kommunikation mit den Forschenden definiert (z. B. Zeit bis zur ersten Reaktion, Zeit bis zur Triage, Zeit bis zur Behebung). Der Prozess SOLLTE sicherstellen, dass die Forschenden regelmäßig über den Status ihrer Meldung informiert bleiben.

DER.7.A9 Integration in das Schwachstellen- und Incident-Management (S)

Verifizierte Schwachstellenmeldungen SOLLTEN systematisch in den internen Schwachstellenmanagementprozess überführt werden. Für kritische Schwachstellen SOLLTE eine direkte Anbindung an den Incident-Response-Prozess existieren, um eine sofortige Reaktion und Behebung zu gewährleisten.

DER.7.A10 Nutzung einer Bug-Bounty-Plattform (S)

Für die effiziente Verwaltung des Programms SOLLTE der Einsatz einer spezialisierten Bug-Bounty-Plattform über einen externen Dienstleister evaluiert werden. Diese Plattformen

SOLLTEN genutzt werden, um die Kommunikation, die Triage, die Auszahlung von Belohnungen und die vertragliche Einbindung von Forschenden zu vereinfachen.

3.3 Anforderungen bei erhöhtem Schutzbedarf

Die folgenden Anforderungen sind exemplarisch und bei erhöhtem Schutzbedarf zu berücksichtigen; die konkrete Festlegung erfolgt im Rahmen einer Risikoanalyse. Der Schutzziel-Bezug ist am Ende jeder Anforderung in Klammern angegeben (C = Vertraulichkeit, I = Integrität, A = Verfügbarkeit).

DER.7.A11 Durchführung von privaten oder zeitlich begrenzten Programmen (H)

Für besonders schützenswerte Systeme oder vor der Einführung neuer kritischer Anwendungen SOLLTEN private, nur für eingeladene und geprüfte Forschende zugängliche Bug-Bounty-Programme durchgeführt werden. Alternativ KÖNNEN zeitlich begrenzte Programme mit hohen Belohnungen genutzt werden. (C, I, A)

DER.7.A12 Proaktives Forscher-Management und Beziehungsaufbau (H)

Es SOLLTEN aktiv Beziehungen zu bekannten und erfolgreichen Sicherheitsforschern aufgebaut werden. Die Institution SOLLTE diese proaktiv in private Programme einladen und eine zielgerichtete Gemeinschaft um ihr Sicherheitsprogramm herum fördern. (C, I, A)

DER.7.A13 Analyse und Optimierung der Programm-Metriken (H)

Das Bug-Bounty-Programm SOLLTE anhand von Metriken kontinuierlich überwacht und optimiert werden. Wichtige Kennzahlen wie die durchschnittliche Zeit bis zur Behebung, die Kosten pro gefundener Schwachstelle oder die am häufigsten betroffenen Systembereiche SOLLTEN regelmäßig analysiert werden, um die allgemeine defensive Sicherheitsstrategie anzupassen. (C, I, A)

DER.7.A14 Verknüpfung von Erkenntnissen mit dem Secure SDLC (H) [Entwickler]

Die aus dem Programm gewonnenen Erkenntnisse über Schwachstellenmuster SOLLTEN systematisch in den Software Development Lifecycle (SDLC) zurückgeführt werden. Entwickler SOLLTEN gezielt zu den im Programm identifizierten Schwachstellenklassen geschult werden, um ähnliche Fehler in der Zukunft strukturell zu vermeiden. (C, I)

4 Weiterführende Informationen

4.1 Wissenswertes

Für die Konzeption und Durchführung von Vulnerability-Disclosure- und

Bug-Bounty-Programmen stellen internationale Standardisierungsorganisationen etablierte Leitfäden zur Verfügung. Besondere Beachtung verdienen hierbei:

- **ISO/IEC 29147:** Information technology — Security techniques — Vulnerability disclosure (beschreibt Best Practices für die Entgegennahme von Schwachstellenmeldungen).
- **ISO/IEC 30111:** Information technology — Security techniques — Vulnerability handling processes (beschreibt den internen Prozess zur Behandlung und Behebung verifizierter Schwachstellen).
- **ENISA:** Good Practice Guide on Vulnerability Disclosure.

Kreuzreferenztable zu elementaren Gefährdungen

Die folgenden elementaren Gefährdungen sind für den Baustein DER.7 Bug-Bounty-Programme von Bedeutung:

- G 0.18 Fehlplanung oder fehlende Anpassung
- G 0.19 Offenlegung schützenswerter Informationen
- G 0.28 Software-Schwachstellen oder -Fehler
- G 0.29 Verstoß gegen Gesetze oder Regelungen
- G 0.40 Verhinderung von Diensten (Denial of Service)

Anforderung	G 0.18	G 0.19	G 0.28	G 0.29	G 0.40
DER.7.A1 (B)	X			X	
DER.7.A2 (B)	X	X			
DER.7.A3 (B)	X	X			
DER.7.A4 (B)				X	
DER.7.A5 (B)	X				
DER.7.A6 (S)	X				X
DER.7.A7 (S)			X		

DER.7.A8 (S)	X	X			
DER.7.A9 (S)			X		
DER.7.A10 (S)	X				
DER.7.A11 (H)		X	X		
DER.7.A12 (H)			X		
DER.7.A13 (H)	X		X		
DER.7.A14 (H)			X		